DBMS 보안 점검 가이드

MySQL, Oracle, Tibero, PostgreSQL, Altibase 등 주요 DBMS의 암호화 알고리즘 설정, 계정 잠금 정책, 원격 접속 제한에 대한 점검 및 조치 사례를 다룹니다.

계정 관리 | 접근 관리 | 보안 점검

MySQL 암호화 알고리즘 설정

MySQL 버전에 따라 사용되는 암호화 플러그인이 다르므로, 버전별 적절한 설정이 필요합니다.

MySQL 5.7

기본적으로 **mysql_native_password** 플러그인이 사용되므로 별도 지정 불필요

```
-- 신규 user 생성
CREATE USER '계정명'@'host'
  IDENTIFIED BY '비밀번호';

-- 기존 user 수정
ALTER USER '계정명'@'host'
  IDENTIFIED '신규 비밀번호';
```

MySQL 8.0

v8.0부터 **caching_sha2_password (SHA-256)** 알고리즘이 기본 적용됨. 5.7에서 업그레이드 시 명시적 지정 필요

```
-- 신규 user 생성
CREATE USER '계정명'@'localhost'
 IDENTIFIED WITH caching_sha2_password
 BY '비밀번호';

-- 기존 user 수정
ALTER USER '계정명'@'localhost'
 IDENTIFIED WITH caching_sha2_password
 BY '비밀번호';
```

Tibero · PostgreSQL 암호화 알고리즘 설정

Tibero — 암호화 알고리즘 확인

```
SELECT "TS#", "ENCRYPTIONALG", "ENCRYPTEDTS"
FROM V$ENCRYPTED_TABLESPACES;
```

알고리즘 적용

```
ALTER TABLESPACE "ENCRYPTED_TS"
  ENCRYPTION USING '적용할 암호화 알고리즘';
```

PostgreSQL — 계정별 알고리즘 확인

```
postgres=# SELECT username, passwd
FROM pg_shadow;
```

알고리즘 적용

```
-- 신규 user
CREATE USER 계정명 password '비밀번호';
-- 기존 user
ALTER USER 계정명 WITH password '비밀번호';
```

※ 기본값으로 **SCRAM-SHA-256** 암호화 알고리즘 적용. **peer** 인증은 로컬 전용으로 OS 사용자명과 DB 사용자명 일치 여부를 확인

D-09 로그인 실패 시 계정 잠금 정책

점검 목적

무차별 대입 공격, 사전 대입 공격 등을 통한 계정 비밀번호 유출 방지

보안 위험

로그인 실패 횟수 미제한 시 자동화된 방법으로 계정·비밀번호 획득 후 DB 접근 및 정보 유출 위험

판단 기준

양호: 로그인 시도 횟수 제한 값 설정
취약: 로그인 시도 횟수 제한 값 미설정

대상 DBMS: Oracle DB, Altibase, Tibero 등 | 중요도: **중(中)**

계정 잠금 정책 — Oracle DB · Altibase

Oracle DB

```
-- Step 1) Profile 파라미터 수정
ALTER PROFILE LIMIT
  FAILED_LOGIN_ATTEMPTS XX;

-- Step 2) 잠금 해제 시간 설정
ALTER PROFILE DEFAULT LIMIT
  PASSWORD_LOCK_TIME UNLIMITED;
-- 또는 특정 일수 후 해제
ALTER PROFILE [Profile명] LIMIT
  PASSWORD_LOCK_TIME XX;
```

※ **utlpwmdng.sql**: 비밀번호 관리 관련 기능 설정 및 Profile 수정 스크립트

Altibase

```
-- Step 1) 사용자 조회
SELECT * FROM system_.sys_users;

-- Step 2) 비밀번호 정책 Property 설정
-- FAILED_LOGIN_ATTEMPTS
-- PASSWORD_LOCK_TIME
-- PASSWORD_LIFE_TIME
-- PASSWORD_GRACE_TIME
-- PASSWORD_REUSE_TIME / MAX
-- PASSWORD_VERIFY_FUNCTION

-- Step 3) 정책 적용
ALTER USER 계정명
 LIMIT (FAILED_LOGIN_ATTEMPTS 7);
```

계정 잠금 정책 — Tibero

Tibero는 사용자별 비밀번호 PROFILE 적용 여부를 확인한 후, PROFILE 설정 내용을 점검하고 필요 시 생성 또는 수정합니다.

01

PROFILE 적용 여부 확인

```
SELECT * FROM dba_users;
```

02

PROFILE 설정 내용 확인

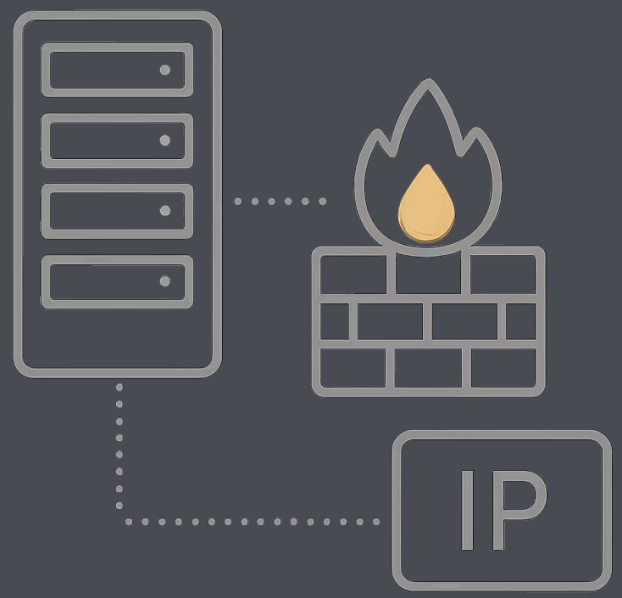
```
SELECT * FROM dba_profiles;
```

FAILED_LOGIN_ATTEMPTS, PASSWORD_LOCK_TIME 등 항목이 **UNLIMITED**인지 확인

03

PROFILE 생성 및 정책 적용

```
CREATE PROFILE prof LIMIT
 FAILED_LOGIN_ATTEMPTS 3
 PASSWORD_LOCK_TIME 1/1440
 PASSWORD_LIFE_TIME 90
 PASSWORD_REUSE_TIME UNLIMITED
 PASSWORD_REUSE_MAX 10
 PASSWORD_GRACE_TIME 10
 PASSWORD_VERIFY_FUNCTION
verify_function;
```



D-10 원격 DB 서버 접속 제한

점검 목적

지정된 IP주소만 DB 서버에 접근 가능하도록 설정하여 비인가자의 접근을 원천 차단

보안 위험

IP 제한 미적용 시 비인가자가 내·외부망 위치에 관계없이 DB 서버에 접근 가능

판단 기준

양호: 지정 IP에서만 접근 가능하도록 제한

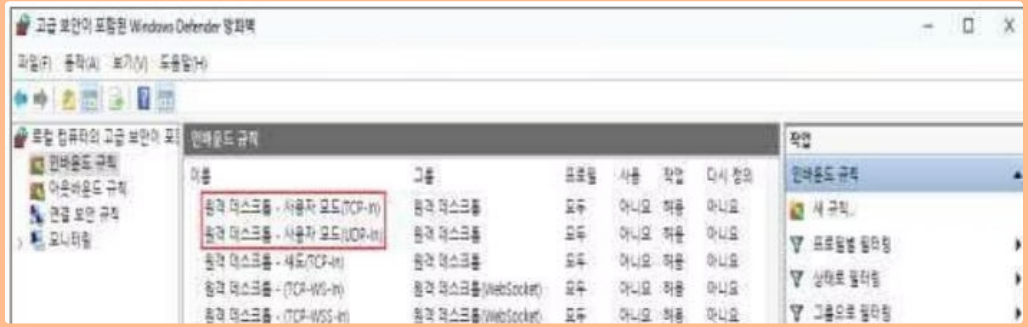
취약: IP 접근 제한 미설정

⚠ 대상: Windows OS, Oracle DB, MySQL, Altibase, Tibero, PostgreSQL 등 | 중요도: **상(上)**

원격 접속 제한 — Windows OS · Oracle DB

Windows OS 방화벽 설정

제어판 → Windows Defender 방화벽 → 고급 설정 → 인바운드 규칙 → **원격 데스크톱 사용자 모드(TCP-In / UDP-In)** 속성 → 영역 → 원격 IP주소 → **다음 IP주소** 선택 후 허용 IP 추가



Oracle DB — sqlnet.ora 설정

```
-- Step 1) oracle 계정 로그인
su - oracle

-- Step 2) sqlnet.ora 파일 편집
vi $ORA_NET/sqlnet.ora

-- Step 3) 파일 끝에 추가
tcp.validnode_checking = yes
tcp.invited_nodes =
 (127.0.0.1, [허용 IP])

-- Step 4) Listener 재시작
$ORACLE_HOME/bin/lsnrctl stop
$ORACLE_HOME/bin/lsnrctl start
```

원격 접속 제한 — MySQL · Altibase · PostgreSQL

MySQL

```
UPDATE user
  SET host = '<접속 IP>'
  WHERE user = '<계정명>'
  AND host = '%';
```

Altibase

altibase.properties 파일의 IP Access Control Lists 수정 후 서버 재구동

```
#access_list = permit, 192.168.3.0, 255.255.255.0
#access_list = permit, 192.168.1.131, 255.255.255.255
```

```
-- 적용 확인
SELECT name, value1 FROM v$property
  WHERE name LIKE 'ACCESS_CONTROL_%';
```

PostgreSQL

postgresql.conf에서 `listen_addresses = 'localhost'` 설정 후, **pg_hba.conf**에서 허용 IP 및 인증 방식 지정

```
host  (DB명)  (사용자)  (허용 IP)  md5
```

※ 두 파일이 연계되므로 하나라도 잘못 설정 시 DB 접속 불가 가능

원격 접속 제한 — Tibero 및 종합 요약

Tibero — LSNR_INVITED_IP 설정

$TB_SID.tip 파일에 허용 IP 입력 (최대 255자, 초과 시 LSNR_INVITED_IP_FILE 사용)

```
LSNR_INVITED_IP=192.168.1.1;
  192.168.2.0/24;192.1.0.0/16
```

※ LSNR_INVITED_IP와 LSNR_DENIED_IP 동시 설정 시 LSNR_INVITED_IP만 적용
※ 루프백(127.0.0.1)은 항상 허용
※ 서버 재기동 없이 변경 적용:

```
ALTER SYSTEM LISTENER PARAMETER RELOAD;
```

점검 항목 종합 요약

→ 암호화 알고리즘 확인 및 설정

MySQL(5.7/8.0), Tibero, PostgreSQL 버전별 적절한 알고리즘 적용

→ 로그인 실패 잠금 정책 (D-09, 중)

Oracle, Altibase, Tibero에서 FAILED_LOGIN_ATTEMPTS 등 정책 설정

→ 원격 접속 IP 제한 (D-10, 상)

Windows, Oracle, MySQL, Altibase, PostgreSQL, Tibero 각각 IP 허용 목록 설정